

VULNERABILITY ASSESSMENT DI METASPLOITABLE

CON NMAP



**TANCREDI
DE SIMONE**

1 Introduzione

Il Vulnerability Assesment è la fase in cui, con ausilio di scanner e strumenti specifici, andiamo a verificare la sicurezza di una rete analizzando i servizi e le porte aperte.

Con questo esercizio andremo ad utilizzare nmap per un vulnerability assesment della macchina virtuale Metasploitable. Essendo stata creata per essere apposta vulnerabile troveremo sicuramente delle falle, il nostro obiettivo sarà riconoscerle, classificarle, e capire a quali bisogni dare priorità.

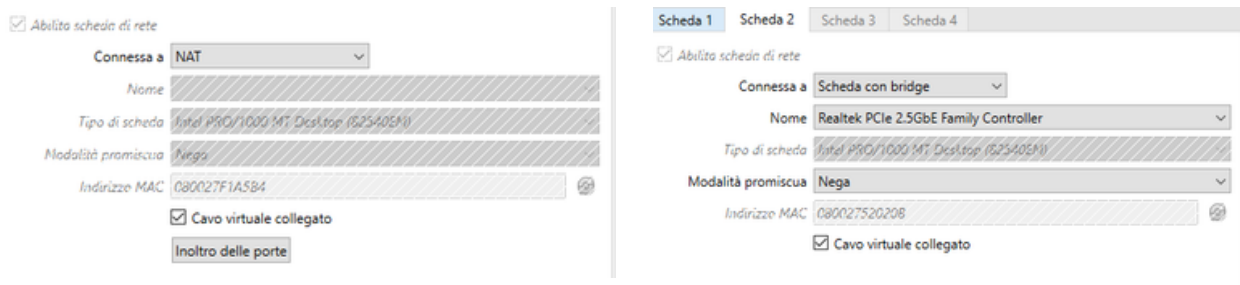
Con Nmap con cui faremo un Host Discovery per vedere gli host disponibili sulla rete, procederemo con un Port scanner per vedere le porte aperte e i servizi attivi, per poi fare un vulnerability scan e capire quali di questi servizi sono effettivamente vulnerabili.

2 Nmap

2.1 Host Discovery

Prima cosa da fare è stata configurare metasploitable.

Ho configurato le schede di rete, la prima su NAT e la seconda con Bridge



Ho avviato la macchina, e impostato in DHCP l'indirizzo ip con **sudo dhclient eth1**.

Indirizzo ip di metasploitable: **192.168.1.102**

Ho avviato Kali e eseguito il ping verso metasploitable per verificare la connessione tra le due macchine.

```
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~/Desktop]
└─$ ping 192.168.1.102
PING 192.168.1.102 (192.168.1.102) 56(84) bytes of data:
64 bytes from 192.168.1.102: icmp_seq=1 ttl=255 time=0.581 ms
64 bytes from 192.168.1.102: icmp_seq=2 ttl=255 time=0.465 ms
64 bytes from 192.168.1.102: icmp_seq=3 ttl=255 time=0.603 ms
64 bytes from 192.168.1.102: icmp_seq=4 ttl=255 time=0.765 ms
^C
— 192.168.1.102 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3067ms
rtt min/avg/max/mdev = 0.465/0.603/0.765/0.106 ms
```

Ora posso procedere con l'Host Discovery con il comando **nmap -sn 192.168.1.102**

```
(kali@kali)-[~/Desktop]
└─$ nmap -sn 192.168.1.102
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-07 08:25 -0400
Nmap scan report for 192.168.1.102
Host is up (0.00047s latency).
Nmap done: 1 IP address (1 host up) scanned in 0.57 seconds
```

Ha logicamente trovato solo Metasploitable e ora abbiamo avviato nmap

2.2 Port Scanning

Ora passiamo al Port scanning per vedere le porte aperte e i servizi attivi con il comando **sudo nmap -sS 192.168.1.102** se volessi farlo senza i privilegi root invece il comando è **nmap -sT 192.168.1.102**

```
(kali㉿kali)-[~/Desktop]
$ sudo nmap -sS 192.168.1.102
[sudo] password for kali:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-07 08:41 -0400
Nmap scan report for 192.168.1.102
Host is up (0.0040s latency).
Not shown: 977 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown

Nmap done: 1 IP address (1 host up) scanned in 6.20 seconds
```

Ho fatto inoltre uno scan dei servizi UDP con **nmap -sU 192.168.1.102**

```
(kali㉿kali)-[~/Desktop]
$ nmap -sU 192.168.1.102
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-07 08:46 -0400
Nmap scan report for 192.168.1.102
Host is up (0.0018s latency).
Not shown: 996 open|filtered udp ports (no-response)
PORT      STATE SERVICE
53/udp    open  domain
111/udp   open  rpcbind
137/udp   open  netbios-ns
2049/udp  open  nfs
```

Ci sarebbero anche degli scan avanzati per bypassare i firewall ma in questo caso non servono perchè non ne è presente uno. (-sN, -sF, -sX)

Ora controlleremo la versione dei servizi, è uno step fondamentale, perchè le vulnerabilità note dipendono dalla versione.

```
(kali@kali) - [~/Desktop]
$ nmap -sV 192.168.1.102
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-07 08:54 -0400
Nmap scan report for 192.168.1.102
Host is up (0.0034s latency).
Not shown: 977 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec?
513/tcp   open  login?
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi      GNU Classpath grmiregistry
1524/tcp  open  bindshell     Metasploitable root shell
2049/tcp  open  nfs           2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql         MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql    PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc           VNC (protocol 3.3)
6000/tcp  open  X11           (access denied)
6667/tcp  open  irc           UnrealIRCd
8009/tcp  open  ajp13         Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

2.3 Vulnerability Scanner

Ora eseguiamo un Vulnerability scanner con **sudo nmap --script vuln -sV 192.168.1.102**

L'output è estremamente lungo, non lo inserirò nel report, per riuscire a capire bene quali vulnerabilità sono presenti ho dato il mio output all'intelligenza artificiale Gemini chiedendogli di elencarmi le vulnerabilità, le porte e perchè sono vulnerabili.

Port 21 - vsFTpd 2.3.4 (Backdoor Critica)

- Vulnerabilità: CVE-2011-2523
- Perché è vulnerabile: Se un utente prova a connettersi via FTP inserendo un nome utente che termina con una faccina sorridente :) (es. user:)), il servizio apre automaticamente una shell di comando sulla porta 6200 con privilegi di root.
- Stato: VULNERABLE (Exploitable). Nmap ha persino confermato l'esecuzione del comando id ottenendo uid=0(root).

Port 25 - SMTP Postfix (Cifratura Debole)

Il servizio di posta elettronica non ha vulnerabilità di esecuzione codice dirette, ma la sua configurazione crittografica è obsoleta e pericolosa.

- Vulnerabilità: SSL POODLE (CVE-2014-3566) e LOGJAM (CVE-2015-4000).
- Perché è vulnerabile:
 - Utilizza protocolli vecchi (SSLv3) e cifrari "Export-grade" a 512-bit (molto facili da decifrare oggi).
 - Un attaccante può eseguire un attacco Man-in-the-Middle (MitM), forzare il downgrade della connessione e intercettare le email in chiaro.

Port 22 - OpenSSH 4.7p1 (Software Obsoleto)

La versione di SSH rilevata risale a circa 15-20 anni fa. Sebbene SSH sia generalmente sicuro, una versione così vecchia espone il sistema a diverse problematiche.

- Vulnerabilità: Numerose, inclusa la User Enumeration (CVE-2018-15473).
- Perché è vulnerabile: Un attaccante può capire quali nomi utente esistono sul sistema (es. "admin", "root", "user") osservando i tempi di risposta del server. Inoltre, la versione 4.7p1 su Ubuntu/Debian dell'epoca soffriva di una generazione di chiavi crittografiche deboli a causa di un bug nel generatore di numeri casuali di OpenSSL.
-

Port 53 - ISC BIND 9.4.2 (DNS Poisoning/DoS)

Anche in questo caso, la versione è arcaica e soggetta a attacchi che possono manipolare il traffico di rete.

- Vulnerabilità: CVE-2008-0122 e altre.
- Perché è vulnerabile: Permette attacchi di Cache Poisoning, dove l'attaccante "inquina" la memoria del server DNS per reindirizzare gli utenti verso siti malevoli invece di quelli reali.

Port 80 - Apache 2.2.8 (Server Web Antico)

Il server web Apache è fermo a una versione del 2008.

- Vulnerabilità: Molteplici vulnerabilità di tipo DoS (Denial of Service) e potenziali perdite di informazioni.
- Perché è vulnerabile: Non include le patch di sicurezza moderne per gestire richieste HTTP malformate che possono mandare in crash il server o permettere l'accesso a directory riservate.

Questo è l'output che mi ha dato, l'ho ovviamente letto e compreso, non solo copiato e incollato. Ovviamente come previsto Metasploitable ha molte vulnerabilità.